

Information Gathering con Kali Linux

Introduzione

L'information gathering è la prima fase di un penetration test e si divide in due categorie:

Ricognizione Passiva (senza contatto diretto col target)

- **whois** — informazioni su domini e IP
- **theHarvester** — email, sottodomini, dipendenti da fonti pubbliche
- **Maltego** — visualizzazione relazioni tra entità
- **Shodan** — ricerca dispositivi connessi a internet
- **Google Dorking** — ricerca avanzata con operatori Google

Ricognizione Attiva (interazione diretta col target)

- **Nmap** — scansione porte, servizi, OS detection
- **dnsrecon** / **fierce** — enumerazione DNS
- **dirb** / **gobuster** — enumerazione directory web
- **Nikto** — scansione vulnerabilità web server
- **Recon-ng** — framework completo di reconnaissance

Workflow Generale

1. Identifica il perimetro (domini, IP range)
 2. Enumera sottodomini e DNS
 3. Scansione porte e servizi con Nmap
 4. Enumerazione web (directory, tecnologie)
 5. Ricerca credenziali esposte e informazioni sensibili
-

1. Identificare il Perimetro

L'obiettivo è mappare tutto ciò che appartiene al target: domini, sottodomini, range IP.

whois

```
whois example.com
```

Restituisce: registrar, date di registrazione, nameserver, contatti, range IP associati.

Risoluzione DNS

```
dig example.com ANY
host example.com
dnsrecon -d example.com
```

Identifica record A, AAAA, MX, NS, TXT, CNAME — ogni record può rivelare servizi o sottodomini.

Enumerazione Sottodomini

Amass (il più completo)

```
amass enum -d example.com
```

Sublist3r (fonti passive, non tocca il target)

```
sublist3r -d example.com
```

fierce (enumerazione DNS con wordlist)

```
fierce --domain example.com
```

theHarvester

```
theHarvester -d example.com -b all
```

Raccoglie email, sottodomini, host, nomi di dipendenti da fonti pubbliche (Google, Bing, LinkedIn, PGP server).

Ricostruzione del perimetro

Alla fine di questa fase dovresti avere una lista tipo:

```
example.com      → 93.184.216.34
mail.example.com → 93.184.216.40
dev.example.com  → 93.184.216.50
vpn.example.com  → 93.184.216.55
Range IP: 93.184.216.0/24
```

Questa lista diventa l'input per la fase successiva (scansione porte e servizi con Nmap).

2. Enumerazione DNS

L'obiettivo è scoprire tutti i record DNS, nameserver, e sottodomini per mappare l'infrastruttura del target.

dnsrecon

Enumerazione standard (A, AAAA, MX, NS, SOA, TXT)

```
dnsrecon -d example.com
```

Zone transfer (se il server DNS lo permette - raro ma devastante)

```
dnsrecon -d example.com -t axfr
```

Con wordlist per brute-force sottodomini

```
dnsrecon -d example.com -D /usr/share/wordlists/dnsmap.txt -t brt
```

fierce

```
fierce --domain example.com
```

Fa enumerazione dei nameserver, poi tenta brute-force sui sottodomini usando una wordlist interna. Mostra anche le reti IP vicine per capire l'infrastruttura.

dnsenum

```
dnsenum example.com
```

Combina: query DNS standard, brute-force sottodomini, zone transfer, e reverse lookup sugli IP trovati.

dig (query manuali)

```
# Tutti i record
```

```
dig example.com ANY +noall +answer
```

```
# Nameserver
```

```
dig example.com NS +short
```

```
# Mail server
```

```
dig example.com MX +short
```

```
# Zone transfer (test)
```

```
dig @ns1.example.com example.com AXFR
```

```
# Reverse DNS
```

```
dig -x 93.184.216.34 +short
```

Tabella Record DNS

Record	Cosa rivela
A / AAAA	IP dei server
MX	Server di posta (potenziale target per phishing)
NS	Nameserver (se vulnerabili → DNS hijacking)
TXT	SPF, DKIM, chiavi di verifica (info su servizi usati)
CNAME	Alias verso servizi cloud (AWS, Azure, ecc.)
SOA	Info amministrative e serial del DNS

Zone Transfer (AXFR)

Se un nameserver permette il zone transfer, ottieni **tutti** i record DNS in un colpo solo. È una misconfigurazione grave ma ancora presente:

```
dig @ns1.example.com example.com AXFR
```

Se funziona, hai l'intera mappa dell'infrastruttura senza fare brute-force.

Output tipico alla fine della fase

```
NS:  ns1.example.com (198.51.100.1)
     ns2.example.com (198.51.100.2)
```

```
MX: mail.example.com (93.184.216.40)
A:  example.com → 93.184.216.34
    www.example.com → 93.184.216.34
    mail.example.com → 93.184.216.40
    dev.example.com → 93.184.216.50
    staging.example.com → 93.184.216.51
TXT: "v=spf1 include:_spf.google.com ~all" → usano Google Workspace
CNAME: cdn.example.com → d1234.cloudfront.net → usano CloudFront
```

3. Scansione Porte e Servizi con Nmap

L'obiettivo è scoprire quali porte sono aperte, quali servizi girano, e che sistema operativo c'è dietro.

Scansioni base

```
# Scansione rapida delle porte più comuni
```

```
nmap 93.184.216.34
```

```
# Scansione di tutte le 65535 porte TCP
```

```
nmap -p- 93.184.216.34
```

```
# Scansione di un range IP
```

```
nmap 93.184.216.0/24
```

```
# Scansione UDP (più lenta, ma importante)
```

```
nmap -sU 93.184.216.34
```

Scansioni stealth (per evitare IDS)

```
# SYN scan (default con privilegi root, non completa il TCP handshake)
```

```
nmap -sS 93.184.216.34
```

```
# Scansione frammentata (pacchetti spezzati)
```

```
nmap -f 93.184.216.34
```

```
# Timing più lento per evitare detection
```

```
nmap -sS -T2 93.184.216.34
```

Scansione Frammentata — Approfondimento

La scansione frammentata (-f) spezza l'header TCP dei pacchetti in **frammenti molto piccoli** (8 byte ciascuno).

Un pacchetto TCP ha un header di almeno 20 byte che contiene: porta sorgente, porta destinazione, flag SYN/ACK, sequence number, ecc. Un IDS/IPS analizza questo header per riconoscere pattern di scansione.

La scansione frammentata spezza il pacchetto così:

Pacchetto normale: [SRC PORT | DST PORT | FLAGS | SEQ | ...] (20+ byte)

Pacchetto frammentato:

Frammento 1: [SRC PORT | DST P...] (8 byte)

Frammento 2: [...ORT | FLAGS | ...] (8 byte)

Frammento 3: [...SEQ | ...] (8 byte)

Il target deve **riassemblare** i frammenti prima di processare il pacchetto. Molti IDS/firewall vecchi o mal configurati non riassemblano i frammenti prima di analizzarli, analizzano solo il primo frammento (incompleto), o scartano frammenti piccoli considerandoli “rumore”.

Varianti:

```
nmap -f 93.184.216.34      # frammenti da 8 byte
nmap -ff 93.184.216.34     # frammenti da 16 byte (meno sospetti)
nmap --mtu 24 93.184.216.34 # MTU personalizzato (deve essere multiplo di 8)
```

Limiti:

- Firewall moderni (con stateful inspection) riassemblano i pacchetti → **-f** non li inganna
- Alcuni sistemi rifiutano pacchetti frammentati → potresti avere falsi negativi
- Rallenta la scansione significativamente

Enumerazione servizi e versioni

Detecta versioni dei servizi sulle porte aperte

```
nmap -sV 93.184.216.34
```

OS detection (richiede root)

```
nmap -O 93.184.216.34
```

La combo completa: porte + versioni + OS + script base

```
nmap -sC -sV -O -p- 93.184.216.34
```

NSE (Nmap Scripting Engine)

Gli script NSE automatizzano task specifici:

Script di default (info base + vulnerabilità note)

```
nmap -sC 93.184.216.34
```

Script per vulnerabilità

```
nmap --script vuln 93.184.216.34
```

Script specifici

```
nmap --script http-enum 93.184.216.34      # enumera directory web
```

```
nmap --script smb-enum-shares 93.184.216.34 # enumera share SMB
```

```
nmap --script ssl-enum-ciphers 93.184.216.34 # analizza SSL/TLS
```

```
nmap --script dns-brute 93.184.216.34      # brute-force DNS
```

Scansione completa consigliata

```
nmap -sC -sV -O -p- -oA scan_result 93.184.216.34
```

- **-sC** — script di default
- **-sV** — version detection
- **-O** — OS detection
- **-p-** — tutte le porte
- **-oA** — salva output in tutti i formati (normale, XML, grepabile)

Interpretazione output

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.9 (Ubuntu)
80/tcp	open	http	Apache httpd 2.4.52
443/tcp	open	ssl/http	nginx 1.18.0
3306/tcp	open	mysql	MySQL 8.0.28

Campo	Cosa guardare
STATE	open = accessibile, filtered = firewall in mezzo
SERVICE	tipo di servizio
VERSION	versione esatta → confronta con CVE noti

Cosa fare con i risultati

- **Porta 22 (SSH)** → tentare brute-force o verificare versioni vulnerabili
- **Porta 80/443 (HTTP/HTTPS)** → passa alla fase 4 (enumerazione web)
- **Porta 3306/5432/1433 (DB)** → verificare se esposti su internet (grave)
- **Porta 445/139 (SMB)** → verificare EternalBlue e simili
- **filtered** → c'è un firewall, prova tecniche di evasion

Scansione di un intero range

```
# Prima una scansione rapida per trovare host vivi
```

```
nmap -sn 93.184.216.0/24
```

```
# Poi scansiona a fondo solo gli host trovati
```

```
nmap -sC -sV -O -iL live_hosts.txt -oA full_scan
```

Tecniche di evasion combinate

```
nmap -sS -f --data-length 25 -T2 -D RND:10 93.184.216.34
```

- **-sS** — SYN scan (non completa handshake)
- **-f** — frammentazione
- **--data-length 25** — aggiunge byte casuali al pacchetto (cambia la firma)
- **-T2** — timing lento
- **-D RND:10** — usa 10 IP decoy (il target vede scan da 11 IP, non sa quale sei tu)

4. Enumerazione Web

L'obiettivo è scoprire directory nascoste, tecnologie usate, file esposti e potenziali punti di ingresso sulle applicazioni web trovate nei punti precedenti.

Enumerazione directory e file

```
# dirb - semplice e veloce
dirb http://example.com

# gobuster - più veloce, usa goroutine
gobuster dir -u http://example.com -w /usr/share/wordlists/dirb/common.txt

# ffuf - il più veloce e flessibile
ffuf -u http://example.com/FUZZ -w /usr/share/wordlists/dirb/common.txt

# Con estensioni specifiche
gobuster dir -u http://example.com -w wordlist.txt -x php,html,txt,bak
```

Enumerazione sottodomini virtuali (vhost)

```
# Trova vhost nascosti sullo stesso IP
gobuster vhost -u http://example.com -w /usr/share/wordlists/dirb/common.txt
ffuf -u http://example.com -H "Host: FUZZ.example.com" -w subdomains.txt
```

Fingerprinting tecnologie

```
# whatweb - identifica CMS, framework, server, plugin
whatweb http://example.com

# wappalyzer (estensione browser o CLI)
# Identifica: WordPress, jQuery, Bootstrap, PHP, ecc.
```

Nikto — scansione vulnerabilità web

```
nikto -h http://example.com
```

Controlla:

- File pericolosi esposti (.git, .env, phpinfo.php)
- Header di sicurezza mancanti
- Configurazioni errate del server
- Software obsoleto con vulnerabilità note

WPScan (se è WordPress)

```
wpscan --url http://example.com --enumerate p,u,vp,vu
```

- p — plugin installati
- u — utenti
- vp — plugin vulnerabili
- vu — utenti vulnerabili

Enumerazione parametri e metodi HTTP

```
# Testa metodi HTTP consentiti
curl -X OPTIONS http://example.com -v
```

```
# arjun - trova parametri nascosti
arjun -u http://example.com/api
```

Cosa cercare

Cosa	Perché
/admin, /login, /panel	Pannelli di amministrazione
/.git, /.env, /.svn	Repository e config esposti
/backup, /old, /dev	Versioni vecchie con bug noti
/api, /v1, /v2	Endpoint API da testare
phpinfo.php, test.php	Info disclosure
/robots.txt, /sitemap.xml	Percorsi nascosti rivelati
.bak, .old, .swp	Backup di file sorgente

Workflow consigliato

1. **Fingerprinting** → whatweb per capire le tecnologie
2. **Directory brute-force** → gobuster o ffuf con wordlist
3. **Nikto** → scansione automatica vulnerabilità
4. **CMS scan** → wpscan se WordPress, joomscan se Joomla, ecc.
5. **Analisi manuale** → esplora le directory trovate, ispeziona sorgenti HTML/JS

Output tipico

```
/ (200) → Homepage
/admin (302) → Redirect a /login
/login (200) → Form di login
/api (401) → API protetta
/.git/HEAD (200) → Repository Git esposto!
/backup.zip (200) → Backup scaricabile!
/phpinfo.php (200) → Info PHP esposte
```

5. Ricerca Credenziali Esposte e Informazioni Sensibili

L'obiettivo è trovare credenziali, dati sensibili o informazioni compromesse che possono essere sfruttate per ottenere accesso.

Ricerca password e credenziali

```
# theHarvester - email e sottodomini da fonti pubbliche
theHarvester -d example.com -b all
```

```
# h8mail - verifica se email sono in data breach
h8mail -t admin@example.com
```

```
# Breach-Parse (da the-xentropy) - cerca in database di breach locali
breach-parse @example.com
```

GitHub Dorking

Cerca codice sorgente, API key e credenziali esposte su GitHub:

```
"example.com" password
"example.com" api_key
"example.com" secret
"example.com" filename:.env
"example.com" filename:config.php
"example.com" filename:id_rsa
```

Google Dorking

```
site:example.com filetype:pdf
site:example.com filetype:xls OR filetype:csv
site:example.com inurl:admin
site:example.com intitle:"index of"
site:example.com filetype:sql
site:example.com "password" OR "username"
site:pastebin.com "example.com"
```

Shodan — dispositivi e servizi esposti

```
# Ricerca per dominio o IP
shodan search "example.com"
shodan host 93.184.216.34

# Filtri utili
shodan search "hostname:example.com port:22"
shodan search "hostname:example.com vuln"
```

Metadati nei documenti

I file PDF, DOCX, XLSX spesso contengono metadati con nomi utente, software usato, percorsi interni:

```
# exiftool - estrae metadati
exiftool document.pdf
exiftool report.docx

# FOCA (Windows) - analisi metadati massiva
```

Paste sites e leak

Cerca su Pastebin, Ghostbin, ecc.

Strumenti:

```
pastesearch -q "example.com"
```

Ricerca manuale su:

pastebin.com

ghostbin.co

dpaste.com

OSINT su persone (dipendenti)

LinkedIn - ruoli, tecnologie, email pattern

Hunter.io - pattern email aziendali

```
hunter.io → example.com → {nome}.{cognome}@example.com
```

social-analyzer - profili social

```
social-analyzer --username "mario.rossi"
```

Cosa cercare

Cosa	Dove
Credenziali in chiaro	GitHub, Pastebin, backup esposti
API key e secret	Codice sorgente, file <code>.env</code> , <code>.git</code>
Email in breach	Have I Been Pwned, database leak
Documenti interni	Google Dorking, metadata analysis
Pattern email	Per costruire wordlist per brute-force
Dipendenti e ruoli	LinkedIn, social media

Workflow consigliato

1. **Email harvesting** → theHarvester per raccogliere email
2. **Breach check** → h8mail per verificare email compromesse
3. **GitHub/Google Dorking** → cerca credenziali e file sensibili
4. **Shodan** → verifica servizi esposti e vulnerabilità note
5. **Metadata analysis** → estrai info da documenti pubblici
6. **Costruzione wordlist** → usa le info raccolte per creare wordlist personalizzate per attacchi brute-force mirati

6. Penetration Testing di Host di Rete Locale

Le fasi precedenti sono orientate principalmente a target web esterni. Quando il target è un **host nella tua rete locale** (es. 192.168.1.x), il workflow cambia: meno focus su DNS e web, più su **servizi di rete, protocolli e enumerazione OS**.

Scansione completa Nmap

```
nmap -sC -sV -O -p- -oA host_scan 192.168.1.100
```

Enumerazione servizi specifici (in base alle porte trovate)

SMB/Windows (445/139)

```
nmap --script smb-enum-shares,smb-enum-users,smb-os-discovery 192.168.1.100
enum4linux -a 192.168.1.100
smbclient -L //192.168.1.100
```

SSH (22)

```
nmap --script ssh2-enum-algos,ssh-hostkey 192.168.1.100
hydra -l user -P wordlist.txt ssh://192.168.1.100
```

SNMP (161)

```
snmp-check 192.168.1.100
onesixtyone -c /usr/share/metasploit-framework/data/wordlists/snmp_default_pass.txt 192.168.1.100
```

RPC (135)

```
rpcclient -U "" 192.168.1.100
```

FTP (21)

```
nmap --script ftp-anon,ftp-bounce,ftp-libopie 192.168.1.100
ftp 192.168.1.100 # prova accesso anonimo
```

Enumerazione OS e utenti

Linux

```
nmap --script ssh-brute,unix-users 192.168.1.100
```

Windows

```
nmap --script smb-enum-domains,smb-enum-groups 192.168.1.100
```

Servizi specifici da testare

Porta	Servizio	Cosa fare
22	SSH	brute-force, versione vulnerabile
21	FTP	accesso anonimo, write access
23	Telnet	credenziali default, sniffing
25	SMTP	enum utenti (VRFY, RCPT TO)
53	DNS	zone transfer, cache poisoning
88	Kerberos	AS-REP roasting, ticket forging
139/445	SMB	share esposti, EternalBlue, credenziali
161	SNMP	community string default, info disclosure

Porta	Servizio	Cosa fare
389	LDAP	anonymous bind, enum utenti
443	HTTPS	cert analysis, web app
1433	MSSQL	sa login, xp_cmdshell
3306	MySQL	root login, file read
3389	RDP	brute-force, BlueKeep
5432	PostgreSQL	default creds, command exec
5900	VNC	brute-force, no auth
6379	Redis	no auth, command exec
27017	MongoDB	no auth, data exfil

Exploitation mirata

Cerca exploit per le versioni trovate

searchsploit OpenSSH 8.9

searchsploit Apache 2.4.52

O usa Metasploit

msfconsole

search type:exploit platform:windows smb

use exploit/windows/smb/ms17_010_eternalblue

Post-exploitation (dopo accesso)

Linux

id, whoami, uname -a

cat /etc/passwd, /etc/shadow (se root)

find / -perm -4000 # SUID binaries

crontab -l, systemctl list-timers

Windows

whoami /all

net user

net localgroup administrators

systeminfo

Differenza principale rispetto al target web

Target Web	Target Rete Locale
DNS, sottodomini, vhost	Servizi di rete, protocolli
Directory brute-force	Enumerazione SMB, SNMP, LDAP
CMS scan (WPScan, ecc.)	Exploit OS-specific (EternalBlue, BlueKeep)
API e parametri HTTP	Credenziali default, accesso anonimo
Google/GitHub Dorking	Post-exploitation, lateral movement

7. Esercitazione Pratica con Metasploitable 2

Metasploitable 2 è una VM **volontariamente vulnerabile**, perfetta per esercitarsi con i tool e capire il workflow completo di un penetration test.

Esercizio 1: Identificazione del target

```
# Trova la VM nella tua rete
nmap -sn 192.168.1.0/24

# Una volta trovato l'IP (es. 192.168.1.50)
```

Esercizio 2: Scansione completa

```
nmap -sC -sV -O -p- -oA metascan 192.168.1.50
cat metascan.nmap
```

Interpreta l'output da solo prima di procedere.

Esercizio 3: Enumerazione servizi

```
# FTP
nmap --script ftp-anon -p 21 192.168.1.50

# SMB
enum4linux -a 192.168.1.50

# SNMP
snmp-check 192.168.1.50

# Web
nikto -h http://192.168.1.50
gobuster dir -u http://192.168.1.50 -w /usr/share/wordlists/dirb/common.txt
```

Esercizio 4: Exploitation (solo dopo aver enumerato)

```
msfconsole
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.1.50
run
```

Esercizio 5: Post-exploitation

```
# Una volta dentro
whoami
id
uname -a
cat /etc/passwd
find / -perm -4000 2>/dev/null
```

Servizi vulnerabili tipici di Metasploitable 2

Porta	Servizio	Vulnerabilità
21	vsftpd 2.3.4	Backdoor nota (CVE-2011-2523)
23	Telnet	Credenziali deboli
25	SMTP (Postfix)	Enum utenti
80	Apache	DVWA, Mutillidae, phpMyAdmin
445	Samba	usermap_script (CVE-2007-2447)
3306	MySQL	Root senza password
6667	UnrealIRCd	Backdoor
8180	Tomcat	Credenziali default (tomcat/tomcat)

Regola d'oro

Non saltare i passaggi: fai prima l'enumerazione, capisci cosa gira, poi scegli l'exploit giusto. È il **workflow** che conta, non il singolo exploit.

8. Tecniche per Bypassare Firewall

Quando Nmap restituisce **filtered**, il firewall sta bloccando i probe di scansione. Esistono diverse tecniche per aggirare questa protezione, anche se nella pratica moderna funzionano solo contro firewall vecchi o mal configurati.

1. IP ID Idle Scan (scansione zombie)

Sfrutta il campo **IP ID** (Identification) nei pacchetti IP. Ogni pacchetto ha un contatore incrementale. Se trovi un host "idle" (che non genera traffico) con IP ID prevedibile, puoi usarlo come proxy indiretto.

```
nmap -sI <zombie_ip> -p 22,80,443 <target>
```

Processo: 1. Verifichi IP ID dello zombie (deve essere incrementale) 2. Fai inviare probe allo zombie (spoofando l'IP del target) 3. Lo zombie manda SYN al target 4. Se porta open → target risponde SYN-ACK → zombie manda RST → IP ID incrementa di 2 5. Se porta closed → target manda RST → zombie ignora → IP ID incrementa di 1 6. Verifichi l'IP ID finale dello zombie per dedurre lo stato della porta

Come trovare uno zombie:

```
nmap -sS -p 80 --script ipidseq.nse <range>
# Risultato "Incremental" = buono zombie
# Risultato "Randomized" = inutile
```

Limiti: Linux moderno e Windows 10+ usano IP ID randomizzato → tecnica quasi inutilizzabile oggi.

2. Fragmentation scan

Spezza l'header TCP in frammenti da 8 byte. Molti firewall vecchi non riassemblano i pacchetti prima di filtrarli.

```
nmap -f -p 22 target          # frammenti da 8 byte
nmap -ff -p 22 target         # frammenti da 16 byte
nmap --mtu 16 -p 22 target    # MTU personalizzato (multiplo di 8)
```

Limiti: Firewall stateful moderni (iptables, pf) riassemblano i pacchetti → non funziona.

3. TCP ACK scan

Manda solo pacchetti ACK (senza SYN). Serve per capire se il firewall è stateful o stateless.

```
nmap -sA -p 22,80,443 target
```

Risultati: - **unfiltered** → il firewall non è stateful (passa ACK) - **filtered** → firewall stateful (blocca ACK non associato a connessione)

Non ti dice se la porta è open, ma ti dice se il firewall traccia le connessioni.

4. TCP Window scan

Sfrutta differenze nel TCP window size per distinguere open da closed anche attraverso firewall.

```
nmap -sW -p 22,80,443 target
```

Funziona solo su sistemi che rispondono con window size diverso per porte open vs closed.

5. Timing analysis

Timing molto lento può bypassare firewall con rate limiting o timeout aggressivi.

```
nmap -sS -T1 --host-timeout 30m -p 22,80,443 target
```

Limiti: Richiede ore/giorni, genera comunque log.

6. Firewall rule enumeration

Scansiona porte comuni per mappare le regole del firewall e dedurre cosa è permesso.

```
nmap -sS -p 21,22,23,25,53,80,110,139,443,445,3306,3389 target
```

Se alcune sono open e altre filtered, puoi ricostruire le regole del firewall.

7. Tecniche di evasion combinate

```
nmap -sS -f --data-length 25 -T2 -D RND:10 target
```

- -sS — SYN scan (non completa handshake)
- -f — frammentazione
- --data-length 25 — byte casuali per cambiare firma
- -T2 — timing lento
- -D RND:10 — 10 IP decoy

Approccio alternativo: altri vettori

Invece di bypassare il firewall, cerca servizi che sono **intenzionalmente esposti**:

Servizio	Porta	Perché spesso aperto
HTTP/HTTPS	80/443	Servizi web pubblici
DNS	53	Risoluzione nomi
SMTP	25/587	Invio email
VPN	1194/443	Accesso remoto

Se trovi credenziali per la VPN, entri **da dentro** la rete e il firewall non filtra più.

Tabella riassuntiva tecniche

Tecnica	Funziona oggi?	Contro
Idle Scan	Raramente	IP ID randomizzato
Fragmentation	Raramente	Firewall stateful
ACK scan	Sì (per info)	Non rivela open/closed
Window scan	Dipende dal target	Non universale
Timing lento	Sì (ma lento)	Tempo, log
Rule enumeration	Sempre	Solo info, non bypass
Evasion combinate	A volte	IDS/IPS moderni

Riepilogo

Alla fine dei 5 punti dovresti avere:

Perimetro: domini, IP, range
 DNS: tutti i record e sottodomini
 Porte/Servizi: porte aperte + versioni
 Web: directory, tecnologie, endpoint
 Credenziali: email, password leak, API key
 Persone: dipendenti, ruoli, email pattern

Questo è il punto di partenza per la fase successiva: **vulnerability assessment** e **exploitation**.